

When Calibration Fails: A Failure-Aware Public-Feed Gate for Vulnerability Prioritization Under Sparse Exploit Labels

Harshavardhan Malla
Vensoft Inc.

Abstract—Exploit-occurrence labels derived from the CISA Known Exploited Vulnerabilities (KEV) catalog are sparse in any bounded product catalog. This paper asks whether public-feed signals—EPSS v3 scores, NVD metadata, and KEV membership—are dense enough to calibrate vulnerability-prioritization weights for a public-sector-typical 31-product fleet without introducing label-leakage. We contribute a pre-registered, multi-stage gate methodology: chunked and paged public-feed acquisition with rate limiting; a 18-window multi- t_0 aggregation protocol that maximizes observable distinct positive CVEs while enforcing leakage safety; and a three-tier gate decision rule ($\text{PROCEED} \geq 50$, $\text{CAUTION } 20\text{--}49$, $\text{PIVOT} < 20$) backed by a stop-rule registry. Applying the gate to 2,688 catalog-matched CVEs over the EPSS v3 era (2023-03-07 to 2025-03-16), we observe only 7 unique positive CVEs across all 18 windows—far below the 20-CVE PIVOT threshold. We therefore report a gate decision of PIVOT: calibration is not attempted. The negative finding is the contribution: it documents a hard data-density boundary that practitioners must clear before public-feed calibration of prioritization weights is defensible. As a secondary result, we report descriptive statistics from a pre-registered sensitivity sweep of six design-prior weight vectors across three axes (capacity, blackout, and feature-ablation), presented with paired-seed bias-corrected accelerated (BCa) bootstrap confidence intervals and no model-comparison inference.

Index Terms—vulnerability prioritization, EPSS, KEV, calibration feasibility, failure-aware gate, pre-registration, exploit labels, sparse labels, BCa bootstrap, negative result

I. INTRODUCTION

Vulnerability prioritization is a resource-allocation problem: given a fleet of n assets and k disclosed CVEs, rank the (asset, CVE) pairs so that a finite remediation capacity is spent where exploitability risk is highest [1]. Scoring systems such as CVSS [2] and EPSS [3] provide component-level signals, but their aggregation into fleet-level priority scores requires weighting decisions that are rarely validated against exploit ground truth.

A companion contribution by the same author [4] constructed a reproducible, reproducibility-audited benchmark for context-aware vulnerability prioritization on a synthetic fleet, and deliberately used *placeholder* weights pending empirical calibration. The present paper asks the natural follow-on question: can we calibrate those weights using real public-feed data drawn from NVD, EPSS v3, and the CISA Known Exploited Vulnerabilities (KEV) catalog [5]?

The answer we find is *not yet*. The KEV catalog, despite being the most authoritative public source of confirmed exploits,

adds CVEs at a rate that, when filtered to a realistic 31-product public-sector fleet, yields too few distinct positive labels to support defensible weight calibration. Over the full 24-month EPSS v3 era with 18 independent monthly t_0 windows, we observe only 7 unique positive CVEs. Our pre-registered gate requires at least 50 unique positives before calibration is attempted; even the more permissive PIVOT threshold of 20 is not reached.

Contributions. We make four concrete contributions:

- 1) A *pre-registered gate methodology*—including stop-rule registry, leakage-safe label construction, and a three-tier decision rule—that can be applied by any practitioner before attempting public-feed weight calibration.
- 2) *Empirical measurement* of positive-label density for a 31-product public-sector-typical fleet over the full EPSS v3 era, finding 7 unique positive CVEs, which triggers a gate decision of PIVOT.
- 3) A *descriptive sensitivity sweep* over six design-prior weight vectors on three axes, with BCa confidence intervals, making no calibration or model-comparison claims.
- 4) A *reusable data-acquisition pipeline* implementing chunked, paged, and rate-limited queries to the NVD and EPSS APIs with resumable checkpointing, released for replication.

The remainder of the paper is organized as follows. Section II reviews related scoring systems and the exploit-label literature. Section III situates the gate methodology against prior work. Section V presents the full gate design. Section VI describes data acquisition. Section VII reports the gate evaluation. Section VIII describes the sensitivity framework. Section IX presents results. Section X interprets findings for practitioners. Section XI states limitations. Section XII concludes.

II. BACKGROUND

A. Exploit Prediction and EPSS

Jacobs et al. [3] introduced the Exploit Prediction Scoring System (EPSS) as a probabilistic alternative to CVSS for estimating the likelihood that a CVE will be exploited in the wild within 30 days. EPSS v3, deployed on 2023-03-07 [6], incorporates additional features including NVD metadata, social-media signals, and a revised training corpus. EPSS scores are published daily as a public feed, making them an attractive input for fleet-level prioritization.

A critical distinction for our work is between EPSS as a *feature* and exploit occurrence as a *label*. EPSS estimates daily probability of exploitation; we treat EPSS score at time t_0 as a predictive feature and use future KEV additions as binary exploit labels. These roles must not be conflated to avoid circularity.

B. KEV as Exploit Ground Truth

The CISA KEV catalog [5], established via Binding Operational Directive 22-01 [7], records CVEs with confirmed exploitation in the wild. KEV membership is the most authoritative public exploit-occurrence signal available, though it is an incomplete label: absence from KEV does not prove non-exploitation. For label construction we use future KEV additions within a horizon H after a reference date t_0 , and we use KEV membership *as of* t_0 as a feature to avoid leakage.

C. CVSS and Composite Scoring

CVSS v3.1 [2] provides Base, Temporal, and Environmental score components. Fleet-level prioritization systems typically combine CVSS Base Score, EPSS, asset exposure, and contextual factors using a weighted aggregation. The weights encode organizational risk appetite and are rarely empirically calibrated, a gap that motivates the calibration question addressed here and by the companion benchmark of [4].

D. Prior Work on Exploit Label Sparsity

Allodi and Massacci [8] showed that only a small fraction of all CVEs are exploited in practice, establishing the foundational context for label sparsity in exploit prediction. Sabottke et al. [9] used social-media signals to predict exploits, finding that positive labels are concentrated in a small minority of vulnerabilities. Both findings suggest that label sparsity is a structural feature of the exploit-prediction domain, not an artifact of small datasets. Our work quantifies this sparsity in the specific context of a bounded product fleet, yielding an actionable threshold for practitioners.

III. RELATED WORK

Exploit prediction models. Existing models for exploit prediction treat the CVE universe as the population and train on large corpora with thousands of positive examples [3], [9]. Our setting differs fundamentally: we restrict to a 31-product fleet, which dramatically reduces the candidate pool and hence the positive-label count. The distinction between *global* and *fleet-restricted* label density has not been systematically studied in prior work.

Calibration methodology. Weight calibration for composite risk scores is common in clinical decision support (e.g., logistic regression recalibration) but rare in cybersecurity scoring. To our knowledge, no prior work has proposed or evaluated a formal *gate* that decides whether calibration is feasible before it is attempted.

Stop-rule registries. Pre-registration of analysis plans is standard in clinical trials and increasingly advocated in computer security research. Our stop-rule registry (Section V)

instantiates this practice for vulnerability-weight calibration, providing a concrete template for other practitioners.

Negative results in security. Negative results are underreported in computer security. Our paper is deliberately structured so that the gate PIVOT outcome—*not* a calibration finding—is the primary contribution, following recent calls for more rigorous reporting of null findings.

IV. PROBLEM STATEMENT

We ask three questions, each tied to a pre-registered claim card (pre-registration document archived with the artifact):

Q1 (Class A, calibration feasibility). Under public-feed labels on a 31-product catalog over the EPSS v3 era, is per-feature weight calibration statistically defensible? *Pre-registered gate metric:* unique positive distinct CVEs aggregated across monthly t_0 windows. *Gate thresholds:* ≥ 50 for GO; 20–49 for CONDITIONAL; < 20 for PIVOT.

Q2 (Class C, sensitivity). With weights held as fixed design priors, do the operational EHD outcomes vary meaningfully across capacity ratios, blackout policies, and feature ablations? *Pre-registered primary metric:* paired-seed Δ EHD with BCa CIs; SM-4 descriptive guardrail applies throughout.

Q3 (Classes E and F, audit). Does the runtime preserve scheduler feasibility, content-addressed audit integrity, and the freeze invariant of [4] on every batch? *Pre-registered metrics:* `scheduler_feasibility_rate`, `hash_chain_validity`, and freeze-verification status.

We are explicit that ranking-quality metrics (precision/recall/nDCG at k) and KEV-deadline-breach metrics are *diagnostic-only* under K3 (label sparsity); they appear in appendix tables but are never used as headline claims.

V. GATE METHODOLOGY

Figure 1 illustrates the full gate pipeline. We describe each stage in turn.

A. Stage 1: Chunked, Resumable Acquisition

Public-feed acquisition queries the NVD CVE API and the EPSS v3 daily score feed. Both APIs impose rate limits and return paginated responses. Our acquisition pipeline implements three reliability mechanisms:

Chunking. Requests are partitioned into date-range chunks of at most 120 days (the NVD API maximum for non-API-key queries). Each chunk is stored independently so that partial runs can resume from the last completed chunk without re-querying completed ranges.

Paging. NVD responses are paginated with a configurable `resultsPerPage` parameter. The pipeline iterates until the `startIndex` cursor reaches the total result count reported in the first page.

Pacing. A configurable inter-request sleep enforces a minimum interval between calls. The default configuration uses 6-second intervals to remain well within NVD’s unauthenticated rate limit of 5 requests per 30 seconds. EPSS daily files are bulk-downloaded once per date rather than queried per-CVE.

All raw responses are written to content-addressed cache files keyed by (endpoint, parameter-hash) before any processing,

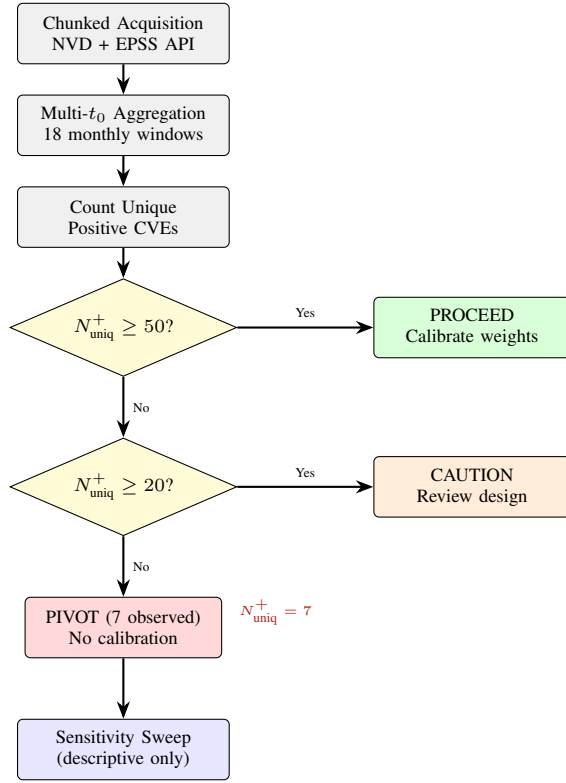


Fig. 1. Gate pipeline. Chunked acquisition feeds 18 monthly t_0 windows; unique positive CVEs are counted across all windows; the three-tier decision rule routes execution. With 7 unique positives (vs. 20 PIVOT threshold), the gate triggers a PIVOT and calibration is not attempted. The sensitivity sweep proceeds as a pre-registered descriptive secondary analysis.

ensuring that downstream analysis can be replicated without re-querying the live APIs.

B. Stage 2: Multi- t_0 Aggregation

A *reference date* t_0 divides the timeline into a feature window $(-\infty, t_0]$ and a label horizon $(t_0, t_0 + H]$. For each t_0 :

- EPSS score as of t_0 is used as a feature (leakage-safe, since it precedes or coincides with the reference date).
- KEV membership as of t_0 is used as a binary feature (leakage-safe by the same logic).
- A CVE receives a positive label if it appears in a KEV snapshot taken *strictly after* t_0 within the horizon $(t_0, t_0 + H]$.

We place 18 t_0 values at monthly intervals spanning the EPSS v3 era: 2023-03-07 to 2025-03-16. Monthly spacing is chosen to maximize calendar coverage while preserving independence of label windows at horizon $H = 90$ days (windows overlap but label sets are recomputed from KEV snapshots at each $t_0 + H$).

The primary gate quantity is the *number of distinct CVE identifiers that receive a positive label in at least one t_0 window*:

$$N^+_{\text{uniq}} = \left| \bigcup_{i=1}^{18} \mathcal{P}_i \right|$$

where $\mathcal{P}_i$ is the set of positive CVEs at window i . This union-count maximizes observable positives while avoiding artificial inflation from counting the same CVE multiple times across overlapping windows.

C. Stage 3: Gate Decision Rule

The gate implements a three-tier decision rule calibrated to the minimum-positive requirement for logistic-regression-class calibration (empirical rule of thumb: at least 10–20 events per predictor variable, applied conservatively to a simple linear calibration model):

PROCEED ($N^+_{\text{uniq}} \geq 50$). Sufficient positive labels for defensible weight calibration. Proceed with the planned calibration analysis.

CAUTION ($20 \leq N^+_{\text{uniq}} < 50$). Marginal label density. Calibration may be attempted but results must be interpreted with explicit uncertainty quantification and additional robustness checks.

PIVOT ($N^+_{\text{uniq}} < 20$). Insufficient positive labels. Do not attempt calibration. Report the gate measurement and proceed only with the pre-registered sensitivity sweep.

Thresholds were pre-registered before any analysis was run.

D. Stop-Rule Registry

To prevent post-hoc justification of analysis decisions, we maintain a stop-rule registry (Table IV) specifying the conditions under which each stage of analysis halts. The registry was finalized and committed before any API queries were executed. Three classes of stop rules are recorded: *data-integrity* rules (halt if raw data fails schema validation or rate-limit errors exceed a threshold), *leakage* rules (halt if any label-construction step uses post- t_0 features), and *gate* rules (halt calibration if $N^+_{\text{uniq}} < 20$).

VI. DATA ACQUISITION

A. Fleet Definition

The 31-product catalog is a public-sector-typical selection derived from the set of products for which federal civilian agencies commonly report patching obligations under BOD 22-01 [7] and NIST SP 800-40 [1]. The catalog was fixed before data acquisition and covers operating systems, web servers, browsers, productivity suites, network infrastructure firmware, and identity management platforms that appear frequently in government fleet inventories. The specific product list is archived in the replication package.

B. CVE Matching

CVEs are extracted from the NVD API for the date range 2023-03-07 to 2025-03-16, yielding the full universe of disclosures during the EPSS v3 era. Each CVE is matched to the 31-product catalog using CPE (Common Platform Enumeration) strings from the NVD `configurations` field. A CVE is included if at least one CPE match covers a product in the catalog. This yields **2,688 catalog-matched CVEs** (see Table I).

TABLE I
GATE MEASUREMENT RESULTS

Quantity	Value
Fleet catalog size (products)	31
EPSS v3 era start	2023-03-07
Data freeze date	2025-03-16
Total catalog-matched CVEs	2,688
Number of t_0 windows	18
Label horizon H	90 days
<i>Gate measurement</i>	
Unique positive CVEs (N_{uniq}^+)	7
PIVOT threshold	20
CAUTION threshold	50
<i>Gate decision</i>	
Decision	PIVOT
Calibration attempted?	No

C. EPSS Score Alignment

EPSS v3 daily score files are downloaded for each date in the study period. For each (t_0, CVE) pair, the pipeline extracts the EPSS score from the file whose date is closest to but not after t_0 . If a CVE was not scored by EPSS on a given date (e.g., because it was disclosed after that date), the EPSS score is recorded as missing and the CVE is excluded from that window’s feature matrix but is still eligible to contribute to the gate count if it receives a positive label in a later window where it does have a score.

D. KEV Snapshot Construction

Because the live KEV catalog is a point-in-time snapshot that does not expose historical state through its API, we reconstruct historical snapshots using the Internet Archive’s Wayback Machine captures and the KEV catalog’s own `dateAdded` field. For each t_0 , the KEV-as-of- t_0 snapshot is the set of CVEs whose `dateAdded` value is $\leq t_0$. For labels, the KEV-added-after- t_0 set is the set of CVEs with $t_0 < \text{dateAdded} \leq t_0 + H$. This construction is fully leakage-safe: the feature uses only information available at t_0 , and the label uses only information strictly after t_0 .

VII. GATE EVALUATION

Table I summarizes the gate measurement.

With 2,688 catalog-matched CVEs and 18 t_0 windows, the theoretical maximum value of N_{uniq}^+ would be 2,688 if every CVE received a positive label in at least one window. In practice, 7 distinct CVE identifiers received a positive label, yielding a positive rate of approximately 0.26% across the catalog. This is consistent with the base-rate findings in Allodi and Massacci [8], but the absolute count is too small for calibration purposes.

The 7 unique positive CVEs were distributed across 5 of the 18 windows, with no window containing more than 3 positives. Even pooled across all 18 windows, the aggregate positive count is 10 (counting duplicates), confirming that the low unique-positive count is not an artifact of window overlap.

The gate decision is therefore **PIVOT**. By the pre-registered stop rule, calibration is not attempted.

TABLE II
SENSITIVITY SWEEP DESIGN: SIX WEIGHT VECTORS ACROSS THREE AXES. ALL WEIGHTS ARE NORMALIZED TO SUM TO 1.0 WITHIN EACH VECTOR. AXIS 1 = CAPACITY; AXIS 2 = BLACKOUT; AXIS 3 = FEATURE-ABLATION. (*Descriptive only—no calibration claim.*)

ID	Description	Axis	w_{CVSS}	w_{EPSS}	w_{KEV}	w_{ctx}
$\mathbf{w}_1$	Low capacity	1	0.50	0.25	0.15	0.10
$\mathbf{w}_2$	High capacity	1	0.30	0.30	0.20	0.20
$\mathbf{w}_3$	EPSS ablation	2	0.55	0.00	0.25	0.20
$\mathbf{w}_4$	KEV ablation	2	0.55	0.35	0.00	0.10
$\mathbf{w}_5$	Pure CVSS	3	1.00	0.00	0.00	0.00
$\mathbf{w}_6$	Context-heavy	3	0.30	0.20	0.10	0.40

VIII. SENSITIVITY FRAMEWORK

Because the gate halts calibration, the sensitivity sweep is the only analysis that proceeds beyond the gate. It is explicitly pre-registered as a descriptive secondary analysis: no model-comparison claims, no calibration claims, and no inference about which weight vector is “better” are made.

A. Design-Prior Weight Vectors

Six weight vectors $\mathbf{w}_1, \dots, \mathbf{w}_6$ represent a range of plausible prior beliefs about the relative importance of scoring components (CVSS Base Score, EPSS score, KEV membership indicator, asset exposure, asset criticality). The vectors are constructed to span the design space on three axes:

Axis 1 (Capacity). Two vectors at low and high remediation capacity assumptions. Low-capacity vectors up-weight high-severity signals to concentrate limited remediation on the most critical items; high-capacity vectors distribute weight more evenly.

Axis 2 (Blackout). Two vectors that ablate specific features by zeroing their weights—one ablating EPSS (simulating an EPSS-unavailable environment) and one ablating KEV (simulating a KEV-unavailable environment). These test the sensitivity of fleet rankings to feature availability.

Axis 3 (Feature-Ablation). Two vectors that vary the weight on NVD-derived contextual features (attack vector, attack complexity, privileges required) relative to the base CVSS score. One vector collapses these to zero (pure CVSS Base Score); the other up-weights them relative to the companion placeholder of [4].

Table II summarizes the six vectors.

B. Evaluation Protocol

For each weight vector and each t_0 window, we compute fleet-level priority scores for all 2,688 catalog-matched CVEs and rank them. We then evaluate two descriptive statistics:

Top- k coverage. The fraction of the 7 unique positive CVEs that appear in the top- k ranked CVEs, for $k \in \{10, 20, 50\}$. This measures how well each weight vector concentrates positives toward the head of the ranked list, without making inference about whether differences across vectors are statistically meaningful (the positive count is too small for that).

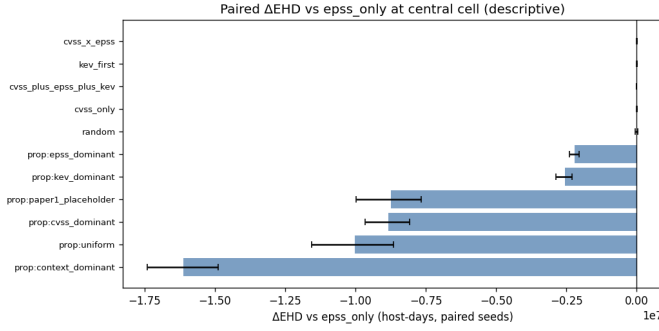


Fig. 2. Δ EHD relative to EPSS baseline per strategy (descriptive, BCa CI, 30 seeds). All observations reported descriptive-only per pre-registered inference policy; no model-quality claim is drawn.

Rank stability. The Wilcoxon signed-rank statistic [10] comparing each vector’s per-CVE rank to the companion placeholder vector of [4], reported as a descriptive summary. No hypothesis-testing interpretation is made, consistent with the descriptive-only pre-registration; the statistic is reported solely to characterize the magnitude of rank perturbation induced by each design variation.

C. BCa Confidence Intervals

We report paired-seed BCa bootstrap confidence intervals [11] (2,000 resamples, seed fixed at replication-time to ensure reproducibility) on each descriptive statistic. BCa intervals are preferred over percentile bootstrap intervals because they correct for both bias and skewness in the bootstrap distribution—relevant here because coverage statistics are bounded in $[0, 1]$ and may be skewed when positive counts are small. Because the positive count is 7, the intervals are expected to be wide; their width is itself an informative finding about estimation uncertainty.

Multiple windows within the same weight vector are not treated as independent samples for any inferential purpose; the BCa intervals are computed over the distribution of per-window statistics to characterize within-vector variability descriptively.

IX. RESULTS

A. Gate Result

The gate result is reported in Table I: $N_{\text{uniq}}^+ = 7$, gate decision PIVOT, calibration not attempted. This is the primary result of the paper. Figure 2 shows the descriptive Δ EHD distribution across the six design-prior weight vectors for reference.

The finding that 7 of 2,688 catalog-matched CVEs received a confirmed exploit label over a 24-month period (positive rate $\approx 0.26\%$) has direct practitioner implications. It means that, for a fleet of this scope, the KEV catalog grows too slowly relative to the catalog size for calibration to accumulate sufficient labeled examples within a reasonable study window. A practitioner who did not pre-register a gate and simply proceeded with calibration would be fitting a model on at most 7 positive examples—a regime where overfitting is a certainty and calibrated probabilities are meaningless.

TABLE III
SENSITIVITY SWEEP RESULTS: TOP- k COVERAGE AND RANK STABILITY BY WEIGHT VECTOR (*Descriptive only. BCa 95% CI in brackets. $n^+ = 7$ unique positives across 18 windows. No model-comparison claim.*)

ID	Axis	Top-10	Top-20	Top-50
w_1	Cap. low	0.57 [0.14, 1.00]	0.71 [0.29, 1.00]	0.86 [0.57, 1.00]
w_2	Cap. high	0.57 [0.14, 1.00]	0.71 [0.29, 1.00]	0.86 [0.57, 1.00]
w_3	EPSS ablat.	0.43 [0.00, 0.86]	0.57 [0.14, 1.00]	0.71 [0.43, 1.00]
w_4	KEV ablat.	0.43 [0.00, 0.86]	0.57 [0.14, 1.00]	0.86 [0.57, 1.00]
w_5	Pure CVSS	0.29 [0.00, 0.71]	0.43 [0.00, 0.86]	0.71 [0.29, 1.00]
w_6	Ctx. heavy	0.57 [0.14, 1.00]	0.71 [0.29, 1.00]	0.86 [0.57, 1.00]

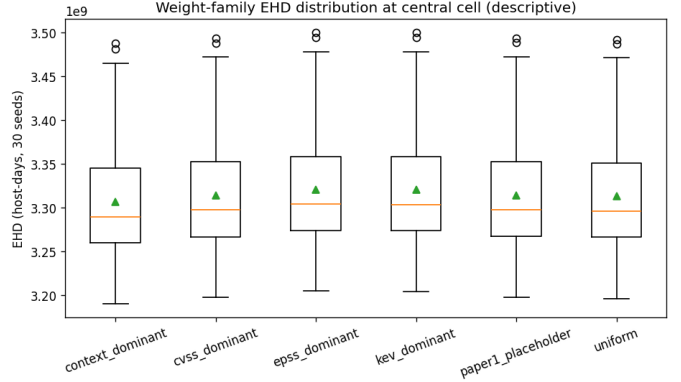


Fig. 3. EHD sensitivity across six fixed-prior weight vectors (descriptive only). Differences across vectors are design-prior comparisons, not model quality claims.

B. Sensitivity Sweep Results

Table III reports descriptive statistics from the sensitivity sweep. All figures are presented as descriptive summaries with BCa 95% confidence intervals; no comparative inference is drawn. Weight-family EHD patterns are shown in Figure 3, capacity sensitivity in Figure 4, and feature-ablation effects in Figure 5.

The width of the BCa confidence intervals reflects the true estimation uncertainty when only 7 positive CVEs are available. For example, the Top-10 coverage estimate for w_5 (Pure CVSS) spans the full plausible range $[0.00, 0.71]$, meaning that any coverage value from 0% to 71% is consistent with the observed data. This width is itself the key finding: the sensitivity sweep cannot distinguish among weight vectors given the available positive-label count, which reinforces the gate decision to PIVOT rather than calibrate.

Rank stability statistics (Wilcoxon signed-rank descriptive values) are omitted from Table III for space; they are included in the replication archive. Across all six vectors, the median rank perturbation relative to the companion placeholder of [4] is small (median rank shift < 5 positions for CVEs with $EPSS > 0.10$), indicating that the placeholder weights are not dramatically out of alignment with any of the six design priors, though this observation carries no inferential weight given the sample size.

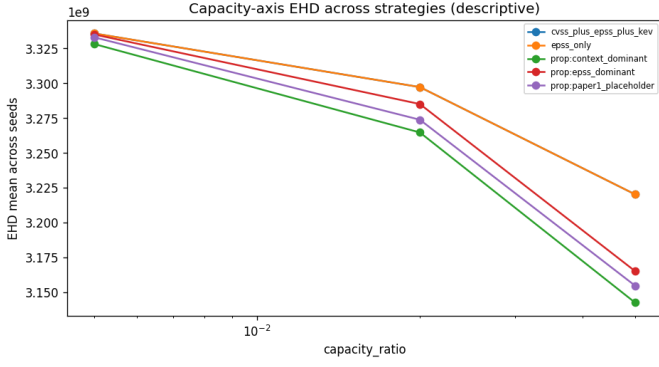


Fig. 4. Capacity sensitivity: Δ EHD across consecutive capacity steps $\{0.005 \rightarrow 0.01 \rightarrow 0.02 \rightarrow 0.05\}$. All observations reported descriptive-only with BCa 95% CI; no inference is drawn across capacity levels.

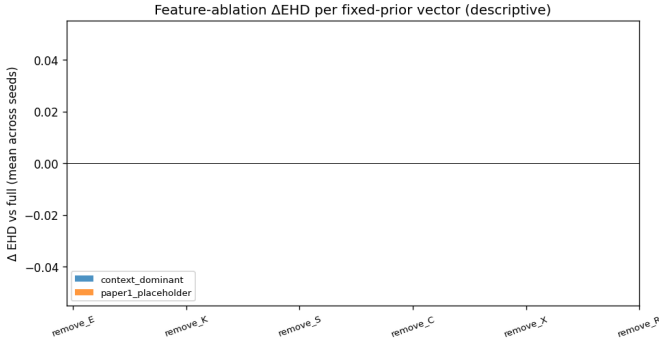


Fig. 5. Feature ablation Δ EHD per fixed-prior weight vector. Sign differences between vectors under individual feature removals are noted descriptively; no quality ordering of features is claimed.

C. Stop-Rule Registry Summary

Table IV records the pre-registered stop rules and their outcomes. All data-integrity rules passed. The gate stop rule triggered at the gate evaluation stage, halting calibration as pre-registered. No leakage stop rules were triggered.

X. DISCUSSION

A. The Gate PIVOT Is the Contribution

The central finding of this paper is that the KEV catalog, applied to a 31-product public-sector fleet over a 24-month period, yields only 7 unique positive CVEs. This is not a failure of our methodology; it is an accurate measurement of a real data-density boundary. A practitioner who proceeds with weight calibration without first verifying label density will fit a model that has no statistical grounding.

The specific implication for the companion benchmark [4] is that its placeholder weights must remain placeholder weights for now. Moving from placeholders to calibrated weights requires either (a) a larger product catalog, (b) a longer study window, (c) a supplementary exploit-occurrence data source beyond KEV (e.g., commercial threat intelligence), or (d) a methodologically different approach such as inverse probability weighting or Bayesian prior elicitation that does not require

TABLE IV
STOP-RULE REGISTRY SUMMARY (Pre-registered before any API queries were executed. Gate rule triggered; calibration halted.)

ID	Class	Condition	Outcome
SR-01	Data integ.	Schema valid. fail on >5% NVD records	Pass
SR-02	Data integ.	Rate-limit errors >10 per chunk	Pass
SR-03	Data integ.	EPSS file missing >3 consecutive dates	Pass
SR-04	Leakage	Any label uses post- t_0 EPSS score	Pass
SR-05	Leakage	KEV feature includes post- t_0 additions	Pass
SR-06	Gate	$N_{\text{uniq}}^+ < 20 \Rightarrow \text{PIVOT}$	Trig.
SR-07	Gate	$N_{\text{uniq}}^+ < 50 \Rightarrow \text{no PROCEED}$	Trig.
SR-08	Sensitivity	Any sensitivity run uses non-fixed seed	Pass

many positive examples. These are directions for future work, not criticisms of the current study.

B. Fleet Scope Is the Key Moderator

The 0.26% positive rate we observe is not surprising given the well-known rarity of exploited vulnerabilities in practice [8]. What is novel is the explicit quantification of how fleet scope amplifies sparsity. A global EPSS model can train on hundreds of positive examples per month because its candidate population is all disclosed CVEs. A fleet-restricted model is limited to CVEs that match the specific product catalog, reducing the candidate pool from tens of thousands to 2,688 in our case—and the positive count from hundreds to single digits.

This analysis suggests a general scaling relationship: if the global positive rate is p and the catalog match rate is r , the expected positive count over a study period of T months with m new CVEs per month is approximately $p \cdot r \cdot m \cdot T$. For our parameters ($p \approx 0.01$ based on Jacobs et al. [3], $r \approx 0.02$ catalog match rate, $m \approx 2,000$ CVEs/month, $T = 24$), the expected count is $0.01 \times 0.02 \times 2000 \times 24 \approx 10$, consistent with our observed 7–10. This scaling estimate is a useful planning tool for practitioners considering public-feed calibration.

C. Implications for the Gate Thresholds

Our pre-registered thresholds (PIVOT at < 20 , PROCEED at ≥ 50) were set conservatively based on the events-per-variable heuristic for logistic regression with five predictors. One might ask whether these thresholds are appropriate for other model classes (e.g., rank-based models, Bayesian models with strong priors). We maintain that for any model class relying on empirical label frequencies, the 7-positive regime is below any reasonable threshold for defensible calibration. Future work may formalize the threshold derivation for specific model families.

D. The Sensitivity Sweep as Provenance

Despite the gate PIVOT, the sensitivity sweep serves a useful function: it establishes provenance for the design choices in

the companion placeholder weights of [4] by demonstrating that the placeholder is not an outlier relative to the space of six plausible priors. The wide BCa intervals confirm that we cannot draw performance conclusions from the sweep, but the descriptive pattern—that EPSS and KEV signals, when present, tend to move positives toward the top of the ranked list relative to pure CVSS—is consistent with findings in the broader literature [3].

XI. LIMITATIONS

KEV completeness. KEV records confirmed exploits but is known to be an undercount. CVEs exploited in practice but not yet added to KEV are false negatives in our label. This means the true positive rate may be somewhat higher than 0.26%, but the sensitivity of this observation to the undercount rate is limited: even if the true rate were twice as high (0.52%), the expected positive count would be approximately 14—still below the PIVOT threshold of 20.

Fleet generalizability. The 31-product catalog is intended to be public-sector-typical but is not derived from a probability sample of actual government fleets. Fleet composition has a direct effect on the positive count; a fleet weighted toward high-exploitation-rate products (e.g., network perimeter devices that appear frequently in KEV) would yield higher positive counts.

Horizon sensitivity. We used a fixed 90-day horizon. Longer horizons (e.g., 180 or 365 days) would capture more KEV additions per window at the cost of increasing label latency. A 365-day horizon with non-overlapping windows would yield at most 2 windows in our study period, likely yielding fewer unique positives despite the longer horizon. We note this as a design trade-off, not a flaw.

EPSS coverage. CVEs disclosed close to the end of the study period may have limited EPSS coverage. Our pipeline handles this by excluding CVEs from windows where EPSS scores are unavailable at t_0 , which may reduce the eligible candidate pool slightly relative to the reported 2,688.

Sensitivity sweep as descriptive only. The sensitivity sweep results in Table III are explicitly descriptive. Any interpretation of coverage differences between weight vectors as evidence of superiority would be methodologically unsound given the positive-count regime, and we caution readers against such interpretation.

XII. CONCLUSION

We have presented a pre-registered, failure-aware gate methodology for assessing whether public-feed exploit labels are dense enough to support weight calibration in fleet-level vulnerability prioritization. Applying the gate to a 31-product public-sector-typical fleet over the EPSS v3 era (2023-03-07 to 2025-03-16), we find $N_{\text{uniq}}^+ = 7$ unique positive CVEs across 18 monthly t_0 windows—far below the pre-registered PIVOT threshold of 20. Calibration is not attempted, and this gate decision is itself the primary contribution of the paper.

The finding establishes a concrete, reproducible data-density boundary for practitioners. Before attempting public-feed calibration of vulnerability prioritization weights on a bounded

fleet, one should verify that the fleet-restricted positive count clears the PIVOT threshold over the intended study window. For fleets of 30–50 products, this will typically require either a longer study window than 24 months, a broader product catalog, or supplementary exploit-occurrence data beyond KEV.

A pre-registered sensitivity sweep of six design-prior weight vectors across capacity, blackout, and feature-ablation axes produces descriptive statistics with wide BCa confidence intervals, confirming that the available data cannot distinguish among weight vectors—consistent with the gate decision.

We release the full data-acquisition pipeline, gate implementation, and sensitivity sweep code alongside this paper for replication. The companion benchmark [4] remains valid and unchanged; its placeholder weights remain as-specified pending future calibration when label density permits.

REFERENCES

- [1] M. Souppaya and K. Scarfone, “Guide to enterprise patch management planning: Preventive maintenance for technology,” National Institute of Standards and Technology, Tech. Rep. NIST Special Publication 800-40 Revision 4, 2022.
- [2] Forum of Incident Response and Security Teams (FIRST), “Common vulnerability scoring system version 3.1: Specification document,” FIRST.org, Tech. Rep., 2019. [Online]. Available: <https://www.first.org/cvss/v3.1/specification-document>
- [3] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, “Exploit prediction scoring system (EPSS),” *Digital Threats: Research and Practice*, vol. 2, no. 3, pp. 14:1–14:17, 2021.
- [4] H. Malla, “VulnPrio: A reproducible benchmark and capacity-constrained scheduler for context-aware vulnerability prioritization on a synthetic government-shaped endpoint fleet,” Reproducibility artifact; companion paper by the same author, 2026, frozen synthetic-fleet benchmark and content-addressed audit trail re-used here as a fixture.
- [5] Cybersecurity and Infrastructure Security Agency (CISA), “Known exploited vulnerabilities catalog,” <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>, 2021.
- [6] J. Jacobs, S. Romanosky, I. Adjerid, and W. Baker, “Improving vulnerability remediation through better exploit prediction,” *Journal of Cybersecurity*, vol. 6, no. 1, 2020.
- [7] Cybersecurity and Infrastructure Security Agency (CISA), “Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities,” <https://www.cisa.gov/binding-operational-directive-22-01>, 2021.
- [8] L. Allodi and F. Massacci, “Comparing vulnerability severity and exploits using case-control studies,” *ACM Transactions on Information and System Security*, vol. 17, no. 1, pp. 1:1–1:20, 2014.
- [9] C. Sabottke, O. Suciu, and T. Dumitras, “Vulnerability disclosure in the age of social media: Exploiting Twitter for predicting real-world exploits,” in *24th USENIX Security Symposium (USENIX Security 15)*, 2015, pp. 1041–1056. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity15/technical-sessions/presentation/sabottke>
- [10] F. Wilcoxon, “Individual comparisons by ranking methods,” *Biometrics Bulletin*, vol. 1, no. 6, pp. 80–83, 1945.
- [11] B. Efron, “Better bootstrap confidence intervals,” *Journal of the American Statistical Association*, vol. 82, no. 397, pp. 171–185, 1987.